DIGITAL FORENSICS TECHNICAL REPORT

Incident Reconstruction & Shellbag Analysis — HTB Sherlock: Baggage

Author:	**Jonathan Di Genova** (Junior SOC Analyst & Cybersecurity Specialist)	**Date:**	November 10, 2026
Lab Platform:	Hack The Box (Sherlock)	**Category / Difficulty:**	DFIR Very Easy
Investigation Scope:	Endpoint Shellbags Parsing, Timeline Reconstruction, Data Staging	**Status:**	Completed (100%)

1. EXECUTIVE SUMMARY & INVESTIGATION SCOPE

During a post-incident investigation on a compromised corporate workstation (User: `steve`), digital forensics analysis was performed to reconstruct adversary activity following initial endpoint access. The primary objective was to track post-exploitation behaviors, including file system navigation, internal search utility execution, network share exploration, data staging, and compression prior to exfiltration.

Because physical temporary folders had been cleaned up or omitted from the forensic collection image, the investigation focused heavily on Windows **Shellbag artifacts** stored within user registry hives (`UsrClass.dat` and NTUSER.DAT). Shellbags persist interaction details, folder view settings, and directory traversal history even after the physical directories or underlying network connections are severed.

2. KEY FORENSICS EVIDENCE & ARTIFACT SUMMARY

Artifact Target	Source Location	Technical Relevance & Findings
Initial Archive & Tool Ingress	User Downloads / Profile Registry	Identified initial downloaded archive and third-party file search utility brought in by the attacker to perform automated internal file discovery.
Credential & Vault Access	`UsrClass.dat` (Shellbags)	Established exact UTC access timestamps for critical local folders containing VPN parameters and stored application passwords.
Network Traversal (UNC)	Shellbags / Network Registry	Revealed access to internal SMB network share (`\\Prod-ns-2\prodshare`) and extraction of sensitive engineering documentation.
Covert Staging Location	`UsrClass.dat` (BagMRU)	Identified an obfuscated single-letter staging directory inside `C:\Users\steve\Pictures\a` used to accumulate data prior to packaging.
Exfiltration Archive	Registry Access Timestamps	Determined exact timestamp when the staged zip file was accessed and prepared for exfiltration.

3. CHRONOLOGICAL INVESTIGATION TIMELINE

Phase 1: Tool Ingress & Reconnaissance Setup
The threat actor initiated the intrusion by downloading a compressed archive to the endpoint. To accelerate internal recon, the attacker deployed a third-party portable search utility (`Everything 1.4.1.1028`) to index and query sensitive filenames across local drives. **Task Completed**

Phase 2: Local File Traversal & Credential Discovery
Using Shellbag analysis, the investigation pinpointed exact timestamps when the attacker navigated to sensitive directories, including VPN configurations and local password manager stores (`OnePassword MasterPass`).
Task Completed

Phase 3: Network Share Excursion & Document Theft
The adversary moved laterally across network assets, connecting to UNC path `\\Prod-ns-2\prodshare`. The attacker pillaged sensitive project plans (Dam Construction Engineer Plans) targeting future infrastructure projects.
Task Completed

Phase 4: Covert Data Staging & Exfiltration Packaging
Bypassing standard `Temp` folders, the attacker created a single-letter obfuscated staging directory within `C:\Users\steve\Pictures\a`. Staged files were compressed into an exfiltration archive accessed at a verified UTC timestamp. **Task Completed**

4. TECHNICAL DEEP DIVE: SHELLBAG FORENSICS & HURDLES

Analytical Breakthrough: During initial staging analysis, standard temporary paths (`C:\Users\steve\AppData\Local\Temp`) yielded no physical traces. By applying Python registry parsers (`regipy`) and string extraction on `UsrClass.dat`, shellbag structures revealed folder interaction history for `C:\Users\steve\Pictures\a`—proving that adversaries leverage legitimate media folders for staging to evade detection.

5. DEFENSIVE LESSONS & MITIGATION RECOMMENDATIONS

- **Deploy Software Restriction Policies (WDAC / AppLocker):** Block unapproved binary execution (such as portable search utilities like *Everything*) from user-writable directories (Downloads, Temp, AppData).
- **Network Share Access Control & Principle of Least Privilege:** Enforce strict ACLs on internal SMB shares and mandate audit logging for read operations on critical engineering shares.
- **EDR Detection Rules for Anomaly Staging:** Configure EDR behavioral alerts for suspicious folder creation in media libraries (e.g., single-character subfolders inside `Pictures` or `Music` containing `.zip` or `.rar` archives).
- **Forensic Artifact Retention:** Ensure endpoint logging captures registry modification events and shellbag updates to maintain visibility even when physical file deletion occurs.